

منصة شاهين الرقمية
سياسة حوكمة تقنية المعلومات والأمن السيبراني
نوفمبر 2025



الاسم المسجل : شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي : طريق الثمامة , الربيع , الرياض
مسؤول المستند : مدير إدارة الجودة والتطوير

Internal

DO NOT COPY

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعاميم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بمنصة شاهين الرقمية ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.

معلومات السياسة				
سياسة حوكمة تقنية المعلومات والأمن السيبراني			عنوان السياسة	
مُستحدثة			حالة السياسة	
لا يوجد			عنوان السياسة السابقة	
لا يوجد			تاريخ السياسة السابقة	
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة			تاريخ المراجعة القادمة	
1SP0001			رقم المستند	
منصة شاهين الرقمية			مالك السياسة	
إدارة الجودة والتطوير			إعدت بواسطة	
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
التوقيع	التاريخ	الاسم	الوظيفة	الإدارة
	2025-12-28	تركي عبدالله العبدلي	مدير إدارة الإلتزام والامتثال	الإدارة الرقابية
	2025-11-26	عنه: هاني هاشم	مدير إدارة الجودة والتطوير	رئيس مراجعة السياسات
اعتماد السياسة				
	2025-12-28	بدر سعد الشايح	العضو المنتدب	الإدارة العليا



1. المقدمة:

1.1 تُعد سياسة حوكمة تقنية المعلومات والأمن السيبراني جزءاً أساسياً لبناء إطار متكامل يُنظّم إدارة تقنية المعلومات والأمن السيبراني ضمن بيئة تشغيلية آمنة، مستدامة، ومتوافقة مع المتطلبات التنظيمية الصادرة عن الجهات الرقابية ذات العلاقة مثل هيئة التأمين والهيئة الوطنية للأمن السيبراني وهيئة الحكومة الرقمية.

2. الهدف من السياسة:

2.1 تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "شاهين") في أن الهدف من هذه السياسة هو وضع إطار حوكمي متكامل لإدارة تقنية المعلومات والأمن السيبراني يضمن توافق الأنشطة التقنية مع الأهداف الاستراتيجية للشركة ومنصة شاهين، وحماية الأنظمة والبيانات والمعلومات من المخاطر والاختراقات وضمان سرّيتها وسلامتها وتوافرها، وتعزيز الامتثال للمتطلبات التنظيمية الصادرة عن الجهات المختصة، بما يساهم في رفع كفاءة الأداء التشغيلي ودعم استدامة الخدمات الرقمية والتحول المؤسسي الآمن.

3. تعاريف:

- 3.1 منصة شاهين (Shahin Platform): المنصة الرقمية التابعة للشركة، والمتخصصة في ربط المنصة كوسيط تأميني بشركات التأمين لتسهيل عمليات الإصدار والتجديد وإدارة العملاء إلكترونياً.
- 3.2 حوكمة تقنية المعلومات (IT Governance): الإطار الذي يحدد المسؤوليات والعمليات التي تضمن استخدام التقنية لدعم الأهداف المؤسسية بفعالية، وبما يحقق الشفافية والمساءلة والرقابة.
- 3.3 الأمن السيبراني (Cybersecurity): مجموعة من الإجراءات والسياسات والتقنية والتنظيمية التي تهدف إلى حماية الأنظمة والشبكات والمعلومات من الوصول أو الاستخدام أو التعديل أو الإفصاح غير المصرح به.
- 3.4 اللجنة التقنية: اللجنة المسؤولة عن الإشراف على حوكمة تقنية المعلومات ومراجعة المشاريع التقنية ومتابعة الأداء والمخاطر.
- 3.5 اللجنة السيبرانية: لجنة أمن المعلومات المسؤولة عن اعتماد سياسات وإجراءات الأمن السيبراني ومراقبة تطبيقها عبر الإدارات المختلفة.
- 3.6 CISO (مسؤول الأمن السيبراني): الوظيفة المسؤولة عن وضع وتنفيذ الاستراتيجية الأمنية للشركة والإشراف على إدارة المخاطر والامتثال الأمني.
- 3.7 خطة استمرارية الخدمات التقنية (IT Continuity Plan): خطة تحدد الإجراءات اللازمة لاستعادة وتشغيل الأنظمة والخدمات التقنية الحيوية في حال حدوث أي طارئ أو انقطاع.
- 3.8 سجل المخاطر التقنية (IT Risk Register): سجل مركزي يُوثّق فيه جميع المخاطر التقنية مع مستوى الخطورة والإجراءات التصحيحية والمسؤوليات.

4. نطاق تطبيق السياسة :

4.1 تُطبّق هذه السياسة على:

- 4.1.1 جميع إدارات الشركة، والموظفين، والمقاولين، والموردين ذوي الصلة بالأنظمة التقنية.
- 4.1.2 جميع الأنظمة، والمنصات، والتطبيقات التقنية، وقواعد البيانات، والبنية التحتية المعلوماتية، بما في ذلك منصة شاهين.
- 4.1.3 جميع عمليات التخطيط، التطوير، التشغيل، الصيانة، وحماية المعلومات داخل الشركة.

5. القطاعات والإدارات ذات العلاقة:

- 5.1 إدارة تقنية المعلومات (تنفيذ الإطار الحوكمي والأمن السيبراني).
- 5.2 إدارة الجودة والتطوير (الرقابة، المراجعة، والتحسين المستمر).
- 5.3 الإدارة المالية (مراجعة الأصول التقنية والعقود).

6. الكيانات ذات العلاقة:

- 6.1 هيئة التأمين.
- 6.2 الهيئة الوطنية للأمن السيبراني (NCA).



6.3 هيئة الحكومة الرقمية (DGA).

6.4 مزودو الخدمات التقنية الخارجيون.

7. قواعد عامة:

7.1 حوكمة تقنية المعلومات

7.1.1 يجب على إدارة تقنية المعلومات إنشاء إطار حوكمة شامل يضمن توافق الأنشطة التقنية مع الأهداف الاستراتيجية

للشركة، وفق مبادئ الكفاءة، الشفافية، واستمرارية الخدمة.

7.1.1.1 يجب أن تكون استراتيجية تقنية المعلومات متوافقة مع الخطة الاستراتيجية العامة للشركة، ويتم مراجعتها سنوياً

لضمان دعم الأهداف التشغيلية والتجارية.

7.1.1.2 تلزم إدارة تقنية المعلومات بتحديد مؤشرات أداء استراتيجية (KPIs) تقيس مساهمة التقنية في تحقيق الأهداف

المؤسسية مثل الكفاءة التشغيلية، التحول الرقمي، ورضا العملاء.

7.1.2 تُنشأ لجنة حوكمة تقنية المعلومات برئاسة الرئيس التنفيذي للعمليات التشغيلية وعضوية مدير تقنية المعلومات ومدير

الجودة والتطوير وممثل من الإدارة المالية، وتختص بمراجعة المشاريع التقنية ومتابعة مؤشرات الأداء والمخاطر.

7.1.3 يجب اعتماد أي مشروع تقني جديد من اللجنة التقنية قبل التنفيذ، مع إعداد دراسة جدوى تتضمن التكلفة، والمخاطر،

والأثر التشغيلي، وخطة التنفيذ.

7.1.3.1 يجب تحديد وتقييم المخاطر التقنية بشكل دوري وتوثيقها في سجل المخاطر المؤسسي بالتنسيق مع إدارة الجودة

والتطوير.

7.1.3.2 تشمل المخاطر التقنية الأعطال المفاجئة، فقدان البيانات، ضعف أداء الموردين، أو فشل الأنظمة المتكاملة مثل

منصة شاهين.

7.1.3.3 تُراجع نتائج تقييم المخاطر نصف سنوياً ضمن اجتماعات اللجنة التقنية، وتُحدَّث خطط المعالجة بناءً على مستوى

الخطورة.

7.1.4 تُلزم إدارة تقنية المعلومات بإعداد تقرير شهري عن أداء الأنظمة التقنية، يشمل نسب الجاهزية، عدد الأعطال، مستوى

رضا المستخدمين، والإجراءات التصحيحية المتخذة.

7.1.5 يجب توثيق جميع التغييرات التقنية عبر نموذج رسمي لطلب التغيير (Change Request) يتضمن المبررات، الموافقات،

وخطة الإشعار المسبق للأقسام المتأثرة.

7.1.6 يُحظر تنفيذ أي تطوير أو تعديل على بيئة الإنتاج دون اختبار مسبق في بيئة تجريبية وموافقة مدير تقنية المعلومات

ومسؤول الأمن السيبراني.

7.1.7 تلزم إدارة تقنية المعلومات بإدارة جميع العقود التقنية وفق سياسات المشتريات، وضمان احتواء العقود على بنود حماية

البيانات والتزامات الموردين بالأمن السيبراني.

7.1.8 يجب حفظ التراخيص التقنية والبرمجيات ضمن سجل إلكتروني محدث يتضمن أسماء البرامج، أرقام التراخيص، تواريخ

التجديد، والجهة المالكة.

7.1.8.1 يجب إنشاء سجل مركزي لجميع الأصول التقنية (أجهزة، خوادم، برمجيات، تراخيص، شبكات) وتحديثه بشكل

مستمر.

7.1.8.2 يتضمن السجل معلومات تفصيلية عن موقع الأصل، حالته، رقم التعريف، تاريخ الشراء، والجهة المسؤولة عنه.

7.1.8.3 تُراجع الأصول التقنية سنوياً بالتنسيق مع الإدارة المالية للتحقق من مطابقة القيم الدفترية ومعدلات الإهلاك.

7.1.9 يجب إعداد أدلة تشغيلية محدثة لجميع الأنظمة التقنية، تشمل إجراءات الاستخدام، الدعم الفني، النسخ الاحتياطي،

وإدارة الأعطال.

7.1.9.1 يجب إنشاء نظام إدارة معرفة داخل إدارة تقنية المعلومات لتوثيق الدروس المستفادة من المشاريع والأعطال التقنية.

7.1.9.2 تُراجع هذه السجلات بشكل ربع سنوي لتحديد فرص التحسين وإدراجها في خطة التطوير التقني السنوية.

7.1.10 تُعد خطة استمرارية الخدمات التقنية (IT Continuity Plan) لضمان تشغيل المنصة في حالات الطوارئ، ويجب اختبارها

سنوياً للتحقق من جاهزيتها وفعاليتها.



DO NOT COPY

- 7.1.11 تلزم إدارة تقنية المعلومات بإنشاء قنوات دعم فني رسمية لمعالجة البلاغات التقنية، على أن يتم الرد خلال 4 ساعات للبلاغات الحرجة و24 ساعة لغيرها.
- 7.1.11.1 تلزم الإدارة بتوثيق مؤشرات الأداء الخاصة بالدعم الفني ومراجعتها شهريًا لقياس فعالية الاستجابة وحل المشكلات.
- 7.1.12 يجب على إدارة تقنية المعلومات الالتزام بجميع الأنظمة والتعليمات الصادرة عن الجهات التنظيمية مثل هيئة التأمين، الهيئة الوطنية للأمن السيبراني، وهيئة الحكومة الرقمية، وتوثيق الامتثال ضمن تقارير المراجعة التقنية.
- 7.1.12.1 تُراجع نتائج فحص الامتثال مرتين سنويًا من قبل لجنة التقنية، وتُحال أي ملاحظات جوهرية إلى إدارة الجودة والتطوير للمتابعة التصحيحية.
- 7.1.12.2 تعمل اللجنة التقنية ولجنة الأمن السيبراني وفق لوائح اللجان المعتمدة لدى الشركة، ويُحدّد إطار الصلاحيات، وآلية الانعقاد، واتخاذ القرارات، والتوثيق، والمسؤوليات الرقابية لكل لجنة بما يتوافق مع أنظمة الحوكمة المعمول بها.
- 7.2 حوكمة الأمن السيبراني:
- 7.2.1 يجب إنشاء لجنة أمن المعلومات برئاسة الرئيس التنفيذي للعمليات التشغيلية وعضوية مدير تقنية المعلومات ومسؤول الأمن السيبراني ومدير الجودة والتطوير.
- 7.2.2 تلزم اللجنة بالإشراف على إعداد واعتماد سياسات الأمن السيبراني، ومتابعة تنفيذها ومراجعتها الدورية.
- 7.2.3 يلتزم مسؤول الأمن السيبراني (CISO) بإعداد تقارير فصلية عن حالة الامتثال والمخاطر، ورفعها إلى اللجنة لمراجعتها واتخاذ القرارات المناسبة.
- 7.2.4 يلتزم مدير المنصة بدمج متطلبات الأمن السيبراني في العمليات اليومية، وضمان تطبيق الضوابط الأمنية على مستوى فرق العمل التابعة له.
- 7.3 السياسات واعتمادها:
- 7.3.1 يجب على لجنة الأمن السيبراني تحديد السياسات والإجراءات المطلوبة وتحديثها بشكل دوري، ورفعها إلى مجلس الإدارة للاعتماد قبل تطبيقها.
- 7.3.2 يُمنع تطبيق أي سياسة جديدة أو تعديل على سياسة قائمة دون اعتماد رسمي موثق من اللجنة والمجلس التنفيذي.
- 7.3.3 تلزم اللجنة بحفظ سجل إلكتروني يوضح تاريخ إصدار واعتماد كل سياسة وأسباب التعديل إن وجد.
- 7.4 إدارة المخاطر السيبرانية:
- 7.4.1 يجب على فريق الأمن السيبراني تنفيذ دورة حياة متكاملة لإدارة المخاطر تشمل: تحديد، تحليل، معالجة، ومراقبة المخاطر التقنية.
- 7.4.2 تُوثّق جميع المخاطر في سجل المخاطر مع تحديد مستوى الخطورة والإجراءات التصحيحية.
- 7.4.3 يلتزم مسؤول الأمن السيبراني بتحديث سجل المخاطر بشكل نصف سنوي على الأقل ورفع تقرير دوري إلى الإدارة التنفيذية.
- 7.4.4 يجب معالجة المخاطر من خلال إجراءات واضحة تشمل: التقليل، التحويل، القبول، أو التجنب، مع توثيق كل قرار ومعياره.
- 7.5 إدارة التغيير والتحديثات التقنية:
- 7.5.1 يجب أن تخضع جميع التغييرات التقنية لإجراء رسمي يسمى طلب تغيير (Change Request) يوضح المبررات والموافقات.
- 7.5.2 يُلزم فريق تقنية المعلومات بتجربة التغييرات في بيئة اختبارية قبل تنفيذها في بيئة الإنتاج.
- 7.5.3 يجب على الفريق إعداد خطة تواصل مسبقة لإبلاغ جميع الأطراف المتأثرة قبل وأثناء وبعد تنفيذ أي تغيير مؤثر على الأنظمة.
- 7.5.4 يُحظر تنفيذ أي تعديل طارئ دون توثيق وموافقة من مدير تقنية المعلومات ومسؤول الأمن السيبراني.
- 7.6 حماية الأنظمة والبنية التحتية:
- 7.6.1 يجب تأمين جميع الخوادم والشبكات وقواعد البيانات ضمن بيئة تقنية محمية ومعزولة وفقًا لتصنيف البيانات.
- 7.6.2 يُلزم فريق التقنية بتطبيق تحديثات الأمان الدورية خلال فترة لا تتجاوز أسبوعين من صدور التحديث.
- 7.6.3 يجب إجراء فحص دوري للثغرات الأمنية واختبارات اختراق نصف سنوية على الأقل.
- 7.6.4 يُمنع توصيل أي أجهزة أو شبكات خارجية ببيئة المنصة دون موافقة لجنة الأمن السيبراني.
- 7.7 إدارة الوصول والصلاحيات:
- 7.7.1 يجب تطبيق مبدأ الحد الأدنى من الصلاحيات (Least Privilege) على جميع حسابات المستخدمين والأنظمة.
- 7.7.2 يلتزم فريق تقنية المعلومات بتفعيل المصادقة الثنائية (MFA) لجميع المستخدمين.
- 7.7.3 تُراجع صلاحيات المستخدمين كل ثلاثة أشهر لإلغاء الحسابات غير النشطة أو الزائدة.

- 7.7.4 يُحظر مشاركة كلمات المرور أو تخزينها في مواقع غير آمنة تحت أي ظرف.
- 7.8 إدارة البيانات وحماية المعلومات:
- 7.8.1 يجب تصنيف جميع البيانات حسب حساسيتها إلى (سرية – داخلية – عامة) وتطبيق ضوابط الوصول المناسبة لكل فئة.
- 7.8.2 تُشفّر البيانات أثناء النقل والتخزين باستخدام بروتوكولات تشفير معتمدة (AES / TLS).
- 7.8.3 يُمنع نسخ أو نقل البيانات الحساسة إلى أجهزة أو وسائط غير مصرح بها.
- 7.8.4 يجب على الإدارات حفظ المستندات الحساسة إلكترونياً ضمن نظام الأرشفة المعتمد.
- 7.9 النسخ الاحتياطي واستعادة البيانات:
- 7.9.1 يجب تنفيذ نسخ احتياطي دوري لجميع الأنظمة الحيوية وفق خطة معتمدة من لجنة الأمن السيبراني.
- 7.9.2 تُخزن النسخ الاحتياطية في مواقع آمنة ومحمية من الكوارث.
- 7.9.3 يجب اختبار استعادة البيانات مرتين سنوياً للتحقق من جاهزية الخطة.
- 7.9.4 يُحظر حذف أو تعديل النسخ الاحتياطية دون تفويض رسمي مكتوب.
- 7.10 سجل التتبع والمراجعة (Audit Trail)
- 7.10.1 يجب تمكين خاصية تتبع الأنشطة (Logs) في جميع الأنظمة والتطبيقات.
- 7.10.2 يلتزم فريق الأمن السيبراني بمراجعة السجلات أسبوعياً لرصد الأنشطة غير الاعتيادية.
- 7.10.3 يجب الاحتفاظ بسجلات التتبع لمدة لا تقل عن 12 شهراً، مع ضمان حمايتها من التعديل أو الحذف.
- 7.10.4 تُرفع تقارير المراجعة إلى لجنة الأمن السيبراني شهرياً لمتابعة الحالات المشبوهة والإجراءات التصحيحية.
- 7.11 خطة التواصل والتدريب الأمني:
- 7.11.1 يجب إعداد خطة تواصل رسمية تحدد المستفيدين وآلية الإبلاغ عن التحديثات أو الحوادث الأمنية.
- 7.11.2 يلتزم مدير المنصة بتنفيذ برامج تدريب إلزامية لجميع الموظفين الجدد قبل منحهم صلاحيات دخول الأنظمة.
- 7.11.3 يجب تنفيذ حملات توعية فصلية تركز على رفع مستوى الوعي بالتهديدات السيبرانية وأساليب الوقاية منها.
- 7.11.4 يلتزم جميع الموظفين بالمشاركة في التدريب وتوقيع نموذج الالتزام بسياسات الأمن السيبراني سنوياً.
- 7.12 الإشعارات والتحديثات:
- 7.12.1 يجب إخطار جميع الإدارات والموظفين والمتعاقدين بأي تغييرات في الأنظمة أو السياسات قبل تطبيقها.
- 7.12.2 يُلزم فريق تقنية المعلومات بإصدار تنبيهات داخلية عند تنفيذ أي تحديث أو إصلاح يؤثر على المستخدمين.
- 7.12.3 تُرسل الإشعارات الرسمية فقط عبر القنوات المعتمدة مثل البريد المؤسسي أو النظام الداخلي.
- 7.12.4 تقوم إدارة الالتزام بإشعار إدارة تقنية المعلومات رسمياً فور ورود أي تعميم أو تعليمات صادرة من هيئة التأمين أو الجهات الرقابية ذات العلاقة، مع تزويدها بتاريخ التنفيذ النهائي المحدد من الجهة الرقابية.
- 7.12.4.1 تلتزم إدارة تقنية المعلومات بدراسة التعميم وتحليل متطلباته فور استلامه، وبما يضمن الالتزام بتاريخ التنفيذ النهائي المحدد من هيئة التأمين.
- 7.12.4.2 تُعد إدارة تقنية المعلومات خطة تنفيذ زمنية متوافقة مع المهلة النظامية المحددة من الجهة الرقابية، مع مراعاة طبيعة التعميم، ونوع الخدمة التأمينية، وحجم الأثر الفني والتشغيلي.
- 7.12.4.3 تُرفع خطة التنفيذ إلى الإدارة التنفيذية لاعتمادها فور إعدادها، وبما لا يؤثر على الالتزام بتاريخ التنفيذ النهائي المحدد من الجهة الرقابية.
- 7.12.4.4 تلتزم الإدارات المختصة بتنفيذ التعميم وفق الخطة المعتمدة، وبما يضمن الالتزام الكامل بتاريخ التنفيذ النهائي المحدد من هيئة التأمين.
- 7.12.4.5 في حال وجود أي مؤشرات لاحتمالية عدم الالتزام بالمهلة النظامية المحددة من الجهة الرقابية، نتيجة متطلبات فنية، أو ارتباطات مع أطراف خارجية، أو أنظمة تشغيلية، يجب على إدارة تقنية المعلومات إشعار إدارة الالتزام فوراً رسمياً، مع توضيح:
- 7.12.4.5.1 سبب الخطر أو التأخير المحتمل،
- 7.12.4.5.2 الأثر النظامي المتوقع،
- 7.12.4.5.3 خطة المعالجة العاجلة،
- 7.12.4.5.4 الموعد المتوقع للإنجاز.

- 7.12.5 تتولى إدارة الالتزام رفع الحالة إلى الإدارة التنفيذية – عند الحاجة – والتنسيق النظامي مع الجهة الرقابية وفق القنوات المعتمدة.
- 7.13 التغذية الراجعة والتحسين المستمر:
- 7.13.1 يجب جمع ملاحظات المستخدمين والإدارات بشكل دوري لقياس فاعلية الإجراءات والسياسات الأمنية.
- 7.13.2 تلتزم لجنة الأمن السيبراني بتحليل الملاحظات وتضمين نتائجها في خطة التحسين السنوية.
- 7.13.3 يُحدث النظام الأمني باستمرار بما يتماشى مع التطورات التقنية والمتطلبات التنظيمية الجديدة.
- 7.14 دورة حياة برنامج أمن المعلومات في منصة شاهين
- 7.14.1 الإطار العام:
- 7.14.1.1 يجب أن يُدار برنامج أمن المعلومات في منصة شاهين ضمن دورة حياة متكاملة تهدف إلى ضمان استمرارية التحسين الأمني وتحديث الضوابط التقنية بشكل مستمر، وتشمل المراحل التالية: التطوير، الاعتماد، التطبيق، الإدارة، والتقييم.
- 7.14.2 مرحلة التطوير (Develop):
- 7.14.2.1 تلتزم إدارة تقنية المعلومات ومسؤول الأمن السيبراني بتطوير وتحديث سياسات وإجراءات ومعايير أمن المعلومات بناءً على نتائج تقييم المخاطر، والتغيرات التنظيمية، وأفضل الممارسات التقنية.
- 7.14.2.2 يجب توثيق مخرجات هذه المرحلة في مستندات رسمية تشمل الأهداف، النطاق، الضوابط، والمسؤوليات التنفيذية.
- 7.14.3 مرحلة الاعتماد (Approve):
- 7.14.3.1 تُعرض السياسات والضوابط الأمنية المطوّرة على لجنة أمن المعلومات لاعتمادها رسميًا قبل تنفيذها، بعد مراجعتها من إدارة الجودة والتطوير للتحقق من التناسق والامتثال.
- 7.14.3.2 يُحظر تطبيق أي ضوابط أو تحديثات أمنية دون اعتماد رسمي موثّق.
- 7.14.4 مرحلة التطبيق (Adopt):
- 7.14.4.1 تلتزم الإدارات ذات العلاقة بدمج متطلبات البرنامج الأمني المعتمد ضمن إجراءاتها التشغيلية اليومية، وإبلاغ الموظفين بالتحديثات الجديدة عبر القنوات الرسمية.
- 7.14.4.2 يجب تدريب جميع المستخدمين على الإجراءات المستحدثة قبل منحهم صلاحيات التطبيق.
- 7.14.5 مرحلة الإدارة (Manage):
- 7.14.5.1 تُنفذ عمليات المراقبة الأمنية، وتتبع الحوادث، وإدارة التهديدات بشكل دوري، وتوثّق التقارير الشهرية الخاصة بالجاهزية الأمنية وسجلات التتبع (Audit Logs).
- 7.14.5.2 تلتزم إدارة تقنية المعلومات بمراجعة الأداء الأمني وضمان استمرارية الأنظمة والنسخ الاحتياطية وفق خطة استمرارية الخدمات التقنية (IT Continuity Plan).
- 7.14.6 مرحلة التقييم (Assess):
- 7.14.6.1 تُجرى مراجعات داخلية دورية لقياس مدى الامتثال لضوابط الأمن السيبراني وتقييم كفاءة الإجراءات التقنية والرقابية.
- 7.14.6.2 يجب إعداد تقارير تقييم فصلية ورفعها إلى لجنة أمن المعلومات متضمنة نتائج الفحص ومقترحات التحسين.
- 7.14.7 مرحلة التحسين المستمر (Improve):
- 7.14.7.1 تلتزم لجنة أمن المعلومات وإدارة تقنية المعلومات بتطبيق خطة التحسين الأمني بناءً على نتائج التقييم والتدقيقات الدورية.
- 7.14.7.2 يجب تحديث سياسات وإجراءات أمن المعلومات بشكل مستمر بما يتناسب مع التطورات التقنية ومتطلبات الجهات التنظيمية مثل هيئة التأمين والهيئة الوطنية للأمن السيبراني.
- 7.14.8 المسؤوليات الإشرافية:
- 7.14.8.1 تُدار دورة حياة برنامج أمن المعلومات تحت إشراف لجنة أمن المعلومات وبدعم مباشر من إدارة تقنية المعلومات وإدارة الجودة والتطوير، لضمان توافق الأنشطة التنفيذية مع أهداف الشركة الاستراتيجية ومتطلبات الحوكمة التقنية.
- 7.15 إدارة الموردين والخدمات التقنية:
- 7.15.1 يجب تقييم الموردين والشركاء التقنيين قبل التعاقد للتأكد من التزامهم بمعايير الأمن السيبراني.

- 7.15.2 يُلزم الموردون بالتوقيع على اتفاقية سرية البيانات (NDA) والتقيد بشروط الحماية المحددة بالعقود.
- 7.15.3 يجب مراقبة أداء الموردين بصفة دورية وإلغاء التعاقد مع أي طرف غير ملتزم بالضوابط الأمنية.
- 7.15.4 يُمنع منح الموردين صلاحيات مباشرة على الأنظمة الإنتاجية دون إشراف أو تفويض مكتوب.
- 7.16 إدارة الحوادث الأمنية والاستجابة للطوارئ:
- 7.16.1 يجب على جميع الموظفين الإبلاغ فوراً عن أي حادث أمني أو محاولة اختراق لفريق الأمن السيبراني.
- 7.16.2 يلتزم الفريق بفتح بلاغ رسمي، توثيق الحادث، والتحقيق في أسبابه خلال 24 ساعة كحد أقصى.
- 7.16.3 تُراجع الحوادث الجسيمة من قبل لجنة الأمن السيبراني خلال أسبوع من وقوعها لتحديد إجراءات المنع المستقبلية.
- 7.16.4 يجب توثيق جميع الحوادث والإجراءات التصحيحية ضمن سجل الحوادث.
- 7.17 المستندات الداعمة:
- 7.17.1 يُحظر تطبيق أي سياسة أو تعديل دون وجود مستندات داعمة معتمدة توضح آلية التنفيذ والمسؤوليات بدقة.
- تشمل المستندات الداعمة المعتمدة لسياسة حوكمة تقنية المعلومات والأمن السيبراني ما يلي:
- 7.17.2 دليل إجراءات أمن المعلومات. (Information Security Procedures Manual)
- 7.17.3 معيار إدارة المخاطر السيبرانية. (Cyber Risk Management Standard)
- 7.17.4 دليل إدارة الحوادث الأمنية. (Incident Management Guideline)
- 7.17.5 معيار التحكم في الوصول وإدارة الصلاحيات. (Access Control Standard)
- 7.17.6 إجراءات النسخ الاحتياطي واستعادة البيانات. (Backup and Recovery Procedures)
- 7.17.7 معيار حماية الشبكات والأنظمة. (Network & System Protection Standard)
- 7.17.8 إجراءات التدقيق والمراجعة الأمنية. (Audit & Monitoring Procedures)
- 7.17.9 خطة التوعية والتدريب الأمني. (Security Awareness & Training Plan)
- 7.17.10 إجراءات إدارة الموردين والخدمات التقنية. (Vendor & Service Management Procedures)
- 7.17.11 تُعد إدارة تقنية المعلومات الجهة المسؤولة عن إعداد وتحديث هذه المستندات، بينما تتولى إدارة الجودة والتطوير مسؤولية مراجعتها واعتمادها من حيث التناسق والحوكمة وتوثيقها ضمن النظام.
8. مسؤوليات السياسة
- 8.1 مدير تقنية المعلومات:
- 8.1.1 مسؤول عن تطبيق بنود حوكمة التقنية وإدارة الأداء، والمشاريع التقنية، وضمان التوافق مع الأهداف المؤسسية.
- 8.2 مسؤول الأمن السيبراني (CISO):
- 8.2.1 مسؤول عن تصميم وتنفيذ الاستراتيجية الأمنية وإدارة المخاطر السيبرانية، ومراقبة الامتثال.
- 8.3 إدارة الالتزام:
- 8.3.1 مسؤولون عن استقبال تعاميم هيئة التأمين والجهات الرقابية، وإشعار إدارة تقنية المعلومات بها فوراً، ومتابعة حالة التنفيذ والتصعيد النظامي عند وجود خطر تأخير.
- 8.4 جميع الموظفين والموردين:
- 8.4.1 ملزمون بتطبيق الضوابط الأمنية والالتزام بسياسات التقنية وحماية المعلومات والبيانات التي بحوزتهم.
- 8.5 إدارة الجودة والتطوير:
- 8.5.1 مسؤولون عن التأكد من تطبيق هذه السياسات من خلال التدقيق والمراجعة الدورية.
9. التعاميم والتعليمات ذات العلاقة:
- 9.1 تعليمات الهيئة الوطنية للأمن السيبراني (NCA ECC – Essential Cybersecurity Controls).
- 9.2 تعليمات هيئة التأمين الخاصة بالحوكمة وحماية البيانات الرقمية.
- 9.3 أدلة هيئة الحكومة الرقمية المتعلقة بحوكمة التقنية واستمرارية الخدمات.
10. حفظ السياسة:
- 10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.



10.2 تحفظ النسخة الورقية من السياسة المعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المحددة في كتيب تقاؤم المستندات ترحل نظامياً إلى حفظ المستندات.

11. مخالفة السياسة:

11.1 يُطبق في حق المخالف لهذه السياسة ماورد في لائحة جزاءات شركة دايمنود المعتمدة.

11.2 في حال مخالفة أحد الموردين أو الأطراف الخارجية، يحق للمنصة إلغاء التعاقد فوراً واتخاذ الإجراءات القانونية اللازمة.



إدارة الجودة والتطوير
Quality & Development Management



Diamond Insurance Broker

IT Governance and Cybersecurity Policy

Nov 2025

Registered Name: Diamond Insurance Broker Company
Head Office: Al Thumama Road, Al Rabie District, Riyadh
Document Owner: Quality & Development Manager

Internal
DO NOT COPY

Translation

Contents	
1	Introduction.....
2	Policy Objective.....
3	Definitions.....
4	Scope of Application.....
5	Related Management and Sectors.....
6	Related Entity.....
7	General Rules.....
8	Policy Responsibility.....
9	Related Circulars and Instructions.....
10	Policy Retention.....
11	Policy Violation.....



Article (1): This document and the information it contains are related to the Shahin digital platform. They may not be used, copied, or disclosed, in whole or in part, to any third party without the prior written consent of Diamond. This restricted notice may not be altered or removed from this document under any circumstances.

Article (2): In the event of any discrepancy between the Arabic and English texts, the Arabic text shall prevail.

1. Introduction

1.1 The IT Governance and Cybersecurity Policy is a fundamental component for establishing an integrated framework that regulates Information Technology management and cybersecurity within a secure, sustainable operating environment, and ensures compliance with regulatory requirements issued by relevant authorities, including the Insurance Authority, the National Cybersecurity Authority (NCA), and the Digital Government Authority (DGA).

2. Policy Objective

2.1 Diamond Insurance Brokers Company (hereinafter referred to as “Shahin”) believes that the objective of this policy is to establish an integrated governance framework for managing Information Technology and cybersecurity in a manner that aligns technical activities with the strategic objectives of the Company and the Shahin Platform, protects systems, data, and information against risks and cyber threats, ensures confidentiality, integrity, and availability, strengthens compliance with regulatory requirements issued by competent authorities, and contributes to improving operational efficiency while supporting the sustainability of digital services and secure institutional transformation.

3. Definitions

3.1 Shahin Platform: The Company’s digital platform that operates as an insurance broker and connects with insurance companies to facilitate electronic issuance, renewals, and customer management.

3.2 IT Governance: The framework that defines responsibilities and processes to ensure that technology is used effectively to support institutional objectives, ensuring transparency, accountability, and oversight.

3.3 Cybersecurity: A set of technical and organizational procedures and policies intended to protect systems, networks, and information from unauthorized access, use, modification, or disclosure.

3.4 IT Committee: The committee responsible for overseeing IT governance, reviewing IT projects, and monitoring performance and risks.

3.5 Cybersecurity Committee: The information security committee responsible for approving cybersecurity policies and procedures and monitoring their implementation across departments.

3.6 CISO (Chief Information Security Officer): The function responsible for setting and executing the Company’s security strategy and overseeing risk management and security compliance.

3.7 IT Continuity Plan: A plan that defines the procedures required to restore and operate critical IT systems and services in the event of an emergency or disruption.

3.8 IT Risk Register: A central log documenting all IT risks, including risk level, corrective actions, and assigned responsibilities.

4. Scope of Application

4.1 This policy applies to:

4.1.1 All Company departments, employees, contractors, and vendors involved in or related to IT systems.

4.1.2 All systems, platforms, technical applications, databases, and information infrastructure, including the Shahin Platform.

4.1.3 All planning, development, operation, maintenance, and information protection activities within the Company.

5. Related Management and Sectors

- 5.1 Information Technology Department (implementation of the governance framework and cybersecurity controls).
- 5.2 Quality and Development Department (oversight, review, and continuous improvement).
- 5.3 Finance Department (review of IT assets and contracts).

6. Related Entity

- 6.1 Insurance Authority
- 6.2 National Cybersecurity Authority (NCA)
- 6.3 Digital Government Authority (DGA)
- 6.4 External technology service providers

7. General Rules

7.1 IT Governance

7.1.1 The IT Department shall establish a comprehensive governance framework ensuring alignment of IT activities with the Company's strategic objectives, based on efficiency, transparency, and service continuity principles.

7.1.1.1 The IT strategy shall be aligned with the Company's overall strategic plan and reviewed annually to ensure support of operational and business objectives.

7.1.1.2 The IT Department shall define strategic KPIs that measure technology's contribution to institutional goals such as operational efficiency, digital transformation, and customer satisfaction.

7.1.2 An IT Governance Committee shall be established, chaired by the Chief Operating Officer, with membership including the IT Director, the Quality & Development Director, and a representative from the Finance Department. The committee shall be responsible for reviewing IT projects and monitoring KPIs and risks.

7.1.3 Any new IT project shall be approved by the IT Committee prior to implementation, supported by a feasibility study covering cost, risks, operational impact, and the implementation plan.

7.1.3.1 IT risks shall be identified and assessed periodically and documented in the corporate risk register in coordination with the Quality & Development Department.

7.1.3.2 IT risks include unexpected outages, data loss, poor vendor performance, or failure of integrated systems such as the Shahin Platform.

7.1.3.3 Risk assessment outcomes shall be reviewed semi-annually in IT Committee meetings, and mitigation plans shall be updated based on risk level.

7.1.4 The IT Department shall prepare a monthly report on IT systems performance, including availability rates, number of incidents, user satisfaction level, and corrective actions taken.

7.1.5 All technical changes shall be documented through an official Change Request form including justifications, approvals, and a prior-notification plan for affected departments.

7.1.6 No development or modification shall be performed in the production environment without prior testing in a sandbox/testing environment and approval from the IT Director and the CISO.

7.1.7 The IT Department shall manage all technology contracts in accordance with procurement policies and ensure contracts include data protection clauses and vendor cybersecurity obligations.

7.1.8 Software licenses shall be maintained in an updated electronic register including software names, license numbers, renewal dates, and the owning entity.

7.1.8.1 A central register for all IT assets (devices, servers, software, licenses, networks) shall be created and continuously updated.

7.1.8.2 The register shall include detailed information such as asset location, condition, identifier number, purchase date, and responsible party.

7.1.8.3 IT assets shall be reviewed annually in coordination with the Finance Department to validate book values and depreciation rates.

7.1.9 Updated operational guides shall be prepared for all IT systems, including usage procedures, technical support, backups, and incident management.

7.1.9.1 A knowledge management system shall be established within the IT Department to document lessons learned from projects and technical incidents.

7.1.9.2 These records shall be reviewed quarterly to identify improvement opportunities and include them in the annual IT development plan.

7.1.10 An IT Continuity Plan shall be developed to ensure platform operation during emergencies, and it shall be tested annually to confirm readiness and effectiveness.

7.1.11 Official support channels shall be established to handle IT tickets, with response times of **4 hours** for critical incidents and **24 hours** for non-critical incidents.

7.1.11.1 Support KPIs shall be documented and reviewed monthly to measure response effectiveness and issue resolution.

7.1.12 The IT Department shall comply with all regulations and instructions issued by authorities such as the Insurance Authority, NCA, and DGA, and document compliance within IT review reports.

7.1.12.1 Compliance assessment results shall be reviewed twice per year by the IT Committee, and any material findings shall be referred to the Quality & Development Department for corrective follow-up.

7.1.12.2 The IT Committee and the Cybersecurity Committee shall operate in accordance with the Company's approved committee charters, defining powers, meeting mechanisms, decision-making, documentation, and oversight responsibilities in line with applicable governance requirements.

7.2 Cybersecurity Governance

7.2.1 An Information Security Committee shall be established, chaired by the Chief Operating Officer and including the IT Director, the CISO, and the Quality & Development Director.

7.2.2 The committee shall oversee the development and approval of cybersecurity policies and monitor their implementation and periodic review.

7.2.3 The CISO shall prepare quarterly reports on compliance status and risks and submit them to the committee for review and decision-making.

7.2.4 The Platform Manager shall integrate cybersecurity requirements into daily operations and ensure implementation of security controls across the teams reporting to him/her.

7.3 Policies and Approval

7.3.1 The Cybersecurity Committee shall determine required policies and procedures, update them periodically, and submit them to the Board of Directors for approval prior to implementation.

7.3.2 It is prohibited to implement any new policy or amend any existing policy without formally documented approval from the committee and the executive board.

7.3.3 The committee shall maintain an electronic register recording the issuance and approval date of each policy and the rationale for amendments, if any.

7.4 Cyber Risk Management

7.4.1 The cybersecurity team shall implement an end-to-end risk management lifecycle including risk identification, analysis, treatment, and monitoring.

7.4.2 All risks shall be documented in the risk register, including risk level and corrective actions.

7.4.3 The CISO shall update the risk register at least semi-annually and submit a periodic report to executive management.

7.4.4 Risks shall be treated using clear options—mitigate, transfer, accept, or avoid—with each decision and its criteria documented.

7.5 Change Management and Technical Updates

7.5.1 All technical changes shall be subject to a formal Change Request procedure specifying rationale and approvals.

7.5.2 The IT team shall test changes in a testing environment before implementing them in production.

7.5.3 The team shall prepare a prior communication plan to inform all affected parties before, during, and after any change that impacts systems.

7.5.4 No emergency change shall be executed without documentation and approval from the IT Director and the CISO.

7.6 Systems and Infrastructure Protection

7.6.1 All servers, networks, and databases shall be secured within a protected and segregated IT environment in accordance with data classification.

7.6.2 The IT team shall apply regular security updates within a maximum of **two weeks** from the release date.

7.6.3 Periodic vulnerability scans and penetration tests shall be conducted at least semi-annually.

7.6.4 Connecting any external devices or networks to the platform environment without the Cybersecurity Committee's approval is prohibited.

7.7 Access and Privileges Management

7.7.1 The Principle of Least Privilege shall be enforced for all user accounts and systems.

7.7.2 Multi-Factor Authentication (MFA) shall be enabled for all users.

7.7.3 User privileges shall be reviewed every **three months** to revoke inactive or excessive access.

7.7.4 Sharing passwords or storing them in insecure locations is strictly prohibited under any circumstances.

7.8 Data Management and Information Protection

7.8.1 All data shall be classified based on sensitivity as (Confidential – Internal – Public), with appropriate access controls applied to each category.

7.8.2 Data shall be encrypted in transit and at rest using approved encryption protocols (AES/TLS).

7.8.3 Copying or transferring sensitive data to unauthorized devices or media is prohibited.

7.8.4 Departments shall retain sensitive documents electronically within the approved archiving system.

7.9 Backup and Data Recovery

7.9.1 Periodic backups shall be performed for all critical systems in accordance with a plan approved by the Cybersecurity Committee.

7.9.2 Backups shall be stored in secure sites protected against disasters.

7.9.3 Data restoration shall be tested twice per year to verify readiness.

7.9.4 Deleting or modifying backups without formal written authorization is prohibited.

7.10 Audit Trail and Review

7.10.1 Activity logging (Logs) shall be enabled across all systems and applications.

7.10.2 The cybersecurity team shall review logs weekly to detect abnormal activities.

7.10.3 Audit logs shall be retained for no less than **12 months**, ensuring they are protected against modification or deletion.

7.10.4 Review reports shall be submitted monthly to the Cybersecurity Committee to monitor suspicious cases and corrective actions.

7.11 Security Communication and Training Plan

7.11.1 A formal communication plan shall be developed to define stakeholders and reporting mechanisms for updates or security incidents.

7.11.2 The Platform Manager shall ensure mandatory training for all new employees before granting system access privileges.

7.11.3 Quarterly awareness campaigns shall be conducted to enhance awareness of cyber threats and prevention measures.

7.11.4 All employees shall participate in training and sign the cybersecurity policy acknowledgment annually.

7.12 Notifications and Updates

7.12.1 All departments, employees, and contractors shall be notified of any changes in systems or policies prior to implementation.

7.12.2 The IT team shall issue internal alerts when implementing any updates or fixes that impact users.

7.12.3 Official notifications shall only be sent via approved channels such as corporate email or the internal system.

7.12.4 The Compliance Department shall formally notify the IT Department immediately upon receiving any circular or instruction issued by the Insurance Authority or other relevant regulators, including the regulator's final implementation deadline.

7.12.4.1 The IT Department shall promptly review and analyze the circular requirements upon receipt to ensure compliance with the Insurance Authority's deadline.

7.12.4.2 The IT Department shall develop an implementation timeline aligned with the regulator's statutory deadline, considering the circular's nature, type of insurance service, and the technical/operational impact size.

7.12.4.3 The implementation plan shall be submitted to executive management for approval immediately upon completion, without compromising compliance with the regulator's final deadline.

7.12.4.4 Relevant departments shall implement the circular in accordance with the approved plan to ensure full compliance with the Insurance Authority's final deadline.

7.12.4.5 If there are indicators of potential non-compliance with the regulator's statutory deadline due to technical requirements, external dependencies, or operational systems, the IT Department shall formally notify Compliance immediately, including:

7.12.4.5.1 the reason for the risk or potential delay,

7.12.4.5.2 the expected regulatory impact,

7.12.4.5.3 the urgent mitigation plan, and

7.12.4.5.4 the expected completion date.

7.12.5 The Compliance Department shall escalate the matter to executive management when necessary and coordinate regulatory communication through approved channels.

7.13 Feedback and Continuous Improvement

7.13.1 User and department feedback shall be collected periodically to assess the effectiveness of security procedures and policies.

7.13.2 The Cybersecurity Committee shall analyze feedback and incorporate findings into the annual improvement plan.

7.13.3 The security program shall be continuously updated in line with technological developments and new regulatory requirements.

7.14 Shahin Information Security Program Lifecycle

7.14.1 General Framework

7.14.1.1 The Shahin Platform information security program shall be managed through an integrated lifecycle aimed at ensuring continuous security improvement and continuous updating of technical controls, covering the following phases: Develop, Approve, Adopt, Manage, and Assess.

7.14.2 Develop

7.14.2.1 The IT Department and the CISO shall develop and update information security policies, procedures, and standards based on risk assessment outcomes, regulatory changes, and technical best practices.

7.14.2.2 Outputs of this phase shall be documented in formal documents covering objectives, scope, controls, and implementation responsibilities.

7.14.3 Approve

7.14.3.1 Developed security policies and controls shall be presented to the Information Security Committee for formal approval prior to implementation, after review by the Quality & Development Department to ensure consistency and compliance.

7.14.3.2 Implementing any security controls or updates without formally documented approval is prohibited.

7.14.4 Adopt

7.14.4.1 Relevant departments shall embed the approved security program requirements into daily operational procedures and notify staff of updates through official channels.

7.14.4.2 All users shall be trained on newly introduced procedures before being granted implementation permissions.

7.14.5 Manage

7.14.5.1 Security monitoring, incident tracking, and threat management activities shall be performed periodically, and monthly reports on security readiness and audit logs shall be documented.

7.14.5.2 The IT Department shall review security performance and ensure systems continuity and backups in line with the IT Continuity Plan.

7.14.6 Assess

7.14.6.1 Periodic internal reviews shall be conducted to measure compliance with cybersecurity controls and evaluate the effectiveness of technical and oversight measures.

7.14.6.2 Quarterly assessment reports shall be prepared and submitted to the Information Security Committee, including inspection results and improvement recommendations.

7.14.7 Improve

7.14.7.1 The Information Security Committee and the IT Department shall implement the security improvement plan based on assessment outcomes and periodic audits.

7.14.7.2 Information security policies and procedures shall be continuously updated to reflect technology developments and regulatory requirements issued by the Insurance Authority and the NCA.

7.14.8 Oversight Responsibilities

7.14.8.1 The information security program lifecycle shall be governed under the supervision of the Information Security Committee, with direct support from the IT Department and the Quality & Development Department, ensuring alignment with strategic objectives and IT governance requirements.

7.15 Vendor and Technology Services Management

7.15.1 Vendors and technical partners shall be assessed prior to contracting to ensure compliance with cybersecurity standards.

7.15.2 Vendors shall be required to sign a Data Confidentiality Agreement (NDA) and comply with protection requirements stipulated in contracts.

7.15.3 Vendor performance shall be monitored periodically, and contracts shall be terminated for any party that fails to comply with security controls.

7.15.4 Granting vendors direct privileges on production systems without supervision or written authorization is prohibited.

7.16 Security Incident Management and Emergency Response

7.16.1 All employees shall immediately report any security incident or attempted breach to the cybersecurity team.

7.16.2 The cybersecurity team shall open an official ticket, document the incident, and investigate its causes within a maximum of **24 hours**.

7.16.3 Major incidents shall be reviewed by the Cybersecurity Committee within one week to define preventive actions.

7.16.4 All incidents and corrective actions shall be documented in the incident register.

7.17 Supporting Documents

7.17.1 It is prohibited to implement any policy or amendment without approved supporting documents that clearly define implementation methods and responsibilities.

Approved supporting documents for the IT Governance and Cybersecurity Policy include:

7.17.2 Information Security Procedures Manual

7.17.3 Cyber Risk Management Standard

7.17.4 Incident Management Guideline

7.17.5 Access Control Standard

7.17.6 Backup and Recovery Procedures

7.17.7 Network & System Protection Standard

7.17.8 Audit & Monitoring Procedures

7.17.9 Security Awareness & Training Plan

7.17.10 Vendor & Service Management Procedures

7.17.11 The IT Department shall be responsible for drafting and updating these documents, while the Quality & Development Department shall be responsible for reviewing them for consistency, governance quality, and documenting them within the system.

8. Policy Responsibility

8.1 IT Director:

8.1.1 Responsible for implementing IT governance requirements, managing performance and IT projects, and ensuring alignment with institutional objectives.

8.2 CISO:

8.2.1 Responsible for designing and executing the security strategy, managing cyber risks, and monitoring compliance.

8.3 Compliance Department:

8.3.1 Responsible for receiving circulars from the Insurance Authority and other regulators, notifying the IT

Department immediately, monitoring implementation status, and escalating regulatory risks when delays are anticipated.

8.4 All Employees and Vendors:

8.4.1 Required to comply with security controls and with IT, information, and data protection policies relevant to the assets and data they handle.

8.5 Quality and Development Department:

8.5.1 Responsible for verifying policy implementation through periodic audit and review.

9. Related Circulars and Instructions

9.1 National Cybersecurity Authority (NCA ECC – Essential Cybersecurity Controls).

9.2 Insurance Authority instructions on governance and digital data protection.

9.3 Digital Government Authority guidelines related to IT governance and service continuity.

10. Policy Retention

10.1 The approved non-editable electronic version shall be retained in the HR system and made accessible to relevant departments.

10.2 The approved hard copy shall be retained by the Quality and Development Department in accordance with the document retention period defined in the Document Retention Schedule, then archived in accordance with the approved records retention process.

11. Policy Violation

11.1 Any violation of this policy shall be subject to the penalties stipulated in Diamond Insurance Brokers' approved Disciplinary and Sanctions Policy.

11.2 In the event of any breach by a vendor or external party, the platform shall have the right to immediately terminate the contract and take the necessary legal actions.

إدارة الجودة والتطوير
Quality & Development Management